

TimeSheets: Threat Report

Updated to align with industry best-practice
threat modelling structure

Security Engineering Nanodegree

June 21, 2026

Executive Summary

This report evaluates encryption-related vulnerabilities in the TimeSheets application using STRIDE threat modelling and a Likelihood x Impact risk model. The analysis focuses on four confirmed encryption weaknesses that expose employee data, authentication data, and network credentials.

- Highest priority: authentication requests are unencrypted in transit. This vulnerability has already been exploited through a confirmed Man-in-the-Middle attack and is ranked Critical with a score of 25.
- Credential storage must be corrected by replacing reversible encryption with Argon2id one-way password hashing and retiring the legacy decryption key.
- Data-at-rest controls must be added using AES-256 database encryption, encrypted backups, and centralized key management through an HSM or KMS.
- DES must be removed from the application and replaced with AES-256-GCM to provide modern confidentiality and integrity protection.
- The recommended audit strategy combines policy, automated cryptography checks, vulnerability scanning, penetration testing, SIEM detection, and key rotation monitoring.

Purpose of this Report

This is a threat model report for TimeSheets. The report describes the threats facing TimeSheets using an industry-standard methodology. The model covers the following sections in recommended order:

Section 1 - Initial Threat Assessment

- o Step 0: Security Objectives & Scope
- o Step 1: Asset Inventory
- o Step 2: Architecture Review (Trust Boundaries, Attack Surface, DFDs)
- o Step 3: Threat Model Diagram
- o Step 4: Identifying Threat Actors
- o Step 5: Threats to the Organisation (STRIDE)

Section 2 - Vulnerability Analysis

Section 3 - Risk Analysis (Likelihood x Impact scoring)

Section 4 - Mitigation Plan

Section 5 - Residual Risk Acceptance & Review

Section 1

Initial Threat Assessment

Step 0: Security Objectives & Scope

Before enumerating assets or threats, the organisation must define what it is protecting and why. This step establishes the strategic foundation for the entire threat model and prevents scope creep during analysis.

Security Objectives

- Protect the confidentiality of employee timekeeping and payroll data.
- Ensure the integrity of hours-worked records to prevent fraudulent entries.
- Maintain availability of the TimeSheets application during business hours.

Compliance & Regulatory Requirements

- GDPR Article 32 requires appropriate technical and organisational measures, including encryption where appropriate, for personal data.
- NIST SP 800-53 and NIST SP 800-131A guide the selection and lifecycle of approved cryptographic controls.
- OWASP Password Storage guidance requires adaptive one-way hashing for passwords rather than reversible encryption.

Acceptable Risk Tolerance

Critical and High encryption risks must not be accepted without executive approval. Critical risks require immediate remediation planning; High risks require a tracked mitigation plan within 30 days; Medium risks require remediation within 90 days or a documented compensating control.

Scope Boundaries

- In scope: TimeSheets web server, application server, TimeSheetsDB, AuthDB, client devices accessing the application, network paths.
- Out of scope: unrelated corporate systems not used by TimeSheets, except where compromised TimeSheets credentials could be reused against them.

Step 1: Asset Inventory

Components and Functions

- TimeSheets Web Server -- serves static content (HTML, images) to clients via HTTP.
- TimeSheets Application Server -- handles business logic and serves dynamic content.
- TimeSheetsDB -- stores employee data; queried by the application server.
- AuthDB -- stores user authentication credentials; queried by the application server.

Overview of Application Functionality

TimeSheets is used by employees to track hours worked. Users log in from their device via the Internet.

Data Flow Summary

Client request -> Internet -> TimeSheets Web Server (static content) -> Application Server (business logic) -> TimeSheetsDB / AuthDB (data retrieval) -> Response returned to client.

Asset Classification

- AuthDB -- Confidentiality: Critical; Integrity: High; Availability: Medium.
- TimeSheetsDB -- Confidentiality: High; Integrity: High; Availability: Medium.
- Application Server -- Confidentiality: Medium; Integrity: High; Availability: High.
- Web Server -- Confidentiality: Medium; Integrity: Medium; Availability: High.

Step 2: Architecture Review -- Trust Boundaries, Attack Surface & Data Flows

A thorough architecture review goes beyond listing flaws. It explicitly maps trust boundaries and entry/exit points, which are the primary mechanism for discovering threats.

Identified Trust Boundaries

- Internet ? Web Server (Boundary 1 -- public untrusted zone)
- Web Server ? Application Server (Boundary 2 -- DMZ to internal)
- Application Server ? TimeSheetsDB / AuthDB (Boundary 3 -- app to data tier)

Entry / Exit Points (Attack Surface)

- HTTP/HTTPS endpoint on Web Server (client-facing)
- Internal API between Web Server and Application Server
- Database connection from Application Server to both DBs
- Administrative and monitoring access paths used by SRE, DBA, and audit teams.

Architecture Flaws Identified

- No encryption at rest -- database servers store data on unencrypted disks.
- No redundancy -- single points of failure across all tiers.
- No perimeter firewall filtering inbound Internet traffic.
- No enforced TLS on client, application, or database communication paths.

Step 3: Threat Model Diagram -- TimeSheets DFD (STRIDE annotated)

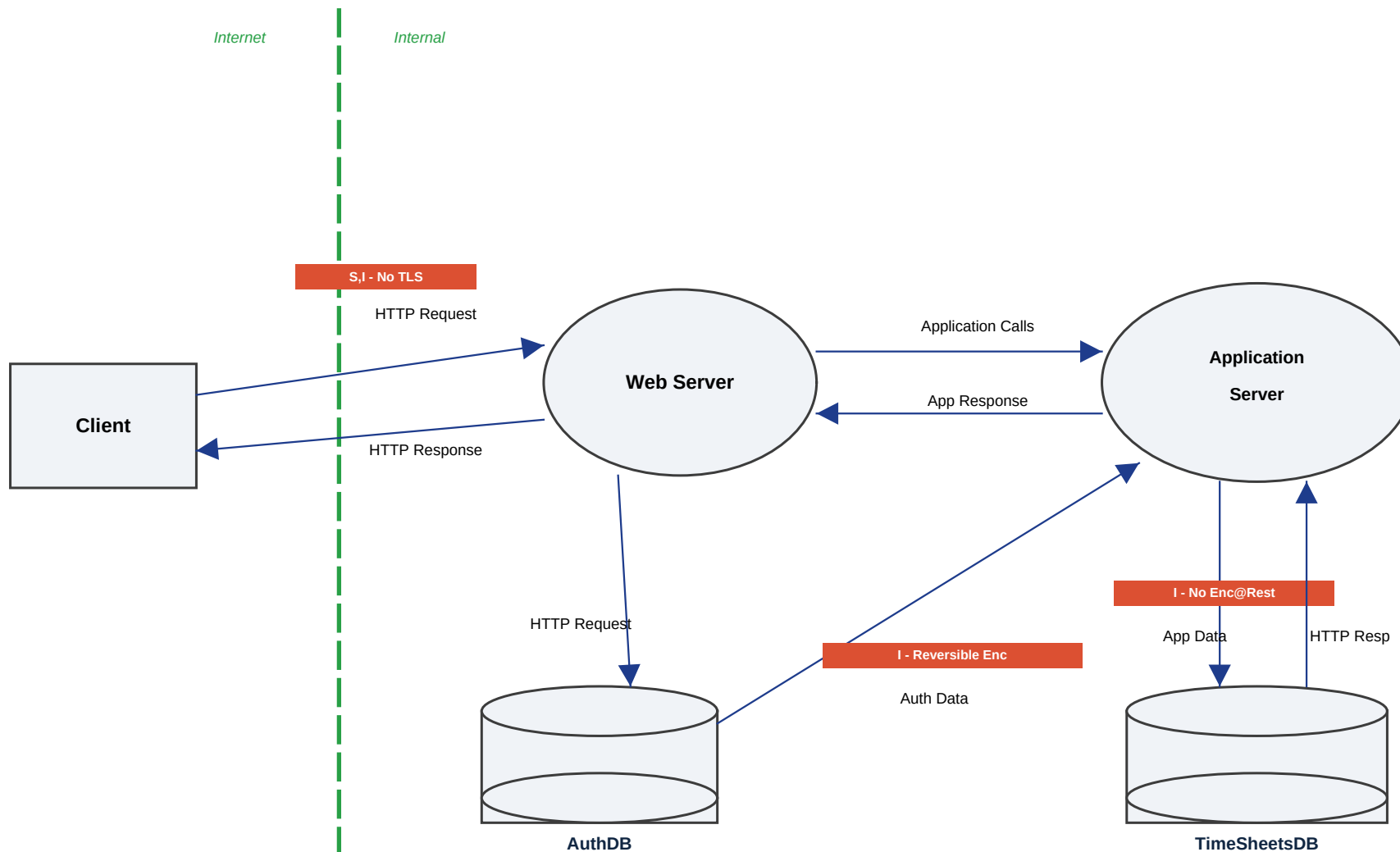


Figure 1: TimeSheets DFD -- STRIDE threat annotations shown in red badges

STRIDE Threat Categories

S = Spoofing Identity
R = Repudiation
D = Denial of Service

T = Tampering with Data
I = Information Disclosure
E = Elevation of Privilege

Key Architecture Observations (Non-Encryption)

1. No firewall/WAF at Boundary 1 (Internet -> Web Server)
2. No network segmentation between Web, App, and Data tiers
3. HTTP used for DB communication (should use encrypted DB protocol)
4. No redundancy -- single points of failure at every tier

Step 4: Identifying Threat Actors

Threat actors are identified before threat enumeration because knowing who the adversaries are shapes which threats are realistic and how likely they are to be attempted.

Primary Threat Actor -- Malicious Internal User

- Evidence: Unexpected login originates from an internal IP address.
- No data exfiltrated or modified -- consistent with reconnaissance by an insider.
- Motivation: potential privilege escalation or data access for personal gain.

Secondary Threat Actor -- External Opportunistic Attacker

- Exploits lack of TLS -- capable of MitM attacks on unencrypted traffic.
- Motivation: credential theft, session hijacking, or competitive espionage.

Tertiary Threat Actor -- Nation-State / Advanced Persistent Threat

- Less likely for a timekeeping application, but the controls recommended in this report still reduce exposure to advanced actors by removing weak cryptography, encrypting all network paths, and centralising key management.

Threat Actor Classification Reference

- o Use MITRE ATT&CK for Enterprise to map actor TTPs to observed behaviours.

Step 5: Threats to the Organisation (STRIDE Analysis)

Threats are enumerated systematically using the STRIDE framework applied to each component and trust boundary crossing.

Completed Threat Model -- Confirmed Threats

- Employee data unencrypted at rest -- Information Disclosure (TimeSheetsDB)
- Authentication data using reversible encryption -- Information Disclosure / Elevation of Privilege (AuthDB)
- Authentication requests unencrypted in transit -- Information Disclosure / Spoofing (Boundary 1 & 2)
- Sensitive data encrypted with DES -- Information Disclosure (weak algorithm, brute-forceable)

Attack Confirmed -- Man-in-the-Middle (MitM)

- A malicious actor sniffed unencrypted traffic and intercepted valid credentials.
- Logs show simultaneous successful logins from the expected IP and a different location -- confirming credential replay.

STRIDE Coverage -- Gaps to Address

- Spoofing: unencrypted credentials allow account impersonation.
- Tampering: DES without authenticated encryption permits undetected data changes.
- Repudiation: audit logs must be retained and correlated with SIEM alerts.
- Information Disclosure: all four confirmed vulnerabilities expose sensitive data.
- Denial of Service: single-instance tiers create availability risk.
- Elevation of Privilege: stolen or decrypted administrator credentials enable escalation.

Section 2

Vulnerability Analysis

Vulnerability 1: Employee Data Unencrypted at Rest

Discovery

During threat modelling, the SRE team confirmed the database server does not have encryption at rest enabled.

Why is this a Vulnerability?

TimeSheetsDB and AuthDB store data on unencrypted disks. If an attacker gains physical access to the storage media (hard drive, backup tape, SSD), obtains a storage snapshot, or accesses a backup, all data is immediately readable with no cryptographic barrier. Database files, backup files, and transaction logs all expose sensitive data in plaintext, eliminating the last line of defence at the storage layer.

Result if Exploited

- Full exposure of all employee PII: names, working hours, and payroll data.
- Regulatory breach: GDPR Article 32 mandates 'appropriate technical measures' including encryption. Fines of up to 4% of annual global turnover apply.
- Mandatory breach notification to affected employees and regulators, causing reputational damage, loss of employee trust, and potential litigation.
- Compound risk: AuthDB exposure combined with Vulnerability 2 enables mass credential compromise across all user accounts simultaneously.
- Significant operational disruption and recovery costs during incident response.

Vulnerability 2: Authentication Data Stored Using Reversible Encryption

Discovery

The DBA team confirmed credentials in AuthDB are stored using reversible (symmetric) encryption rather than a one-way hash.

Why is this a Vulnerability?

Reversible encryption means encrypted passwords can be decrypted back to plaintext by anyone who obtains both the ciphertext and the encryption key. Unlike one-way hashing algorithms (bcrypt, Argon2id, PBKDF2), reversible encryption does not prevent bulk password recovery -- the decryption key is typically stored on the same server or in the same codebase. OWASP explicitly states passwords must never be stored using reversible encryption. An attacker who compromises the database (easier given Vulnerability 1) can decrypt ALL user credentials in a single operation.

Result if Exploited

- Mass account takeover for every user simultaneously, including administrators.
- Credential stuffing against external services: employees reuse passwords, so recovered credentials may unlock email, banking, and other corporate systems.
- Complete authentication bypass -- attackers can impersonate any employee.
- If admin credentials are recovered: full system compromise, data exfiltration, or ransomware deployment becomes possible.

Vulnerability 3: Authentication Requests Unencrypted in Transit

Discovery

The security team confirmed authentication requests are transmitted in plaintext over the network.

Why is this a Vulnerability?

The threat model DFD shows the Client communicating with the Web Server via plain HTTP across the Internet trust boundary (Boundary 1). Credentials travel in cleartext, visible to any on-path observer or Man-in-the-Middle attacker. The DFD also shows HTTP used between the Web Server and AuthDB, and between the App Server and TimeSheetsDB -- all four trust boundary crossings are unencrypted. This directly enabled the confirmed MitM attack: logs show simultaneous logins from the expected IP and a second, unexpected location.

Result if Exploited

- Direct credential theft confirmed: attacker captured valid credentials in transit and replayed them to gain access from a different location.
- Session cookie theft via traffic interception enables persistent access without needing the password again.
- Replay attacks: captured credentials remain valid until the victim changes their password -- the window of exploitation is unlimited.
- Internal traffic interception: an insider with network access can also capture credentials at Boundaries 2 and 3 (internal tiers).

Vulnerability 4: DES Algorithm in Use

Discovery

While conducting threat modelling, the security team identified sensitive data being stored using the Data Encryption Standard (DES) algorithm.

Why is this a Vulnerability?

DES uses a 56-bit key, demonstrated insecure in 1998 when the EFF Deep Crack cracked a DES key in 56 hours using \$250,000 of hardware. NIST formally withdrew DES (FIPS 46-3) in 2005 and explicitly prohibits its use under NIST SP 800-131A Rev. 2. Today, cloud compute makes brute-forcing a 56-bit key achievable in minutes at minimal cost. Additionally, DES in ECB/CBC mode provides no integrity protection -- ciphertext can be tampered with undetected.

Result if Exploited

- Any DES-encrypted data can be decrypted by a well-resourced attacker once they obtain the ciphertext (e.g., via the storage vulnerability above).
- Employee timekeeping records, payroll data, and PII fields protected only by DES are effectively exposed.
- Regulatory non-compliance: GDPR 'appropriate technical measures' are not met; PCI-DSS explicitly prohibits DES if payment data is in scope.
- No integrity protection means DES-encrypted fields can be silently tampered with, corrupting timekeeping records without any detection mechanism.

Additional Architecture Issues Identified from the DFD

Issue 1: No Firewall/WAF at Boundary 1 (Internet -> Web Server)

The DFD shows a direct, unfiltered path from the Client to the Web Server with no inspection or filtering layer between them.

- o Recommendation: Deploy a Web Application Firewall (WAF) at Boundary 1 to filter SQLi, XSS, and CSRF attempts, rate-limit login requests, and block known malicious IP ranges.
- o Why: A WAF is the first line of defence, reducing the attack surface before any request reaches the application tier.

Issue 2: No Network Segmentation Between Tiers

The DFD shows Web Server, App Server, and databases appearing on the same logical network with no internal firewalls between tiers.

- o Recommendation: Segment into three zones -- DMZ (Web Server only), Application tier, and Data tier. Apply strict firewall rules so only the App Server can query the databases.
- o Why: Segmentation limits lateral movement -- a compromised Web Server cannot directly reach the database tier.

Issue 3: HTTP Used for Database Communication

The DFD shows HTTP Request/Response between the App Server and TimeSheetsDB. Databases should communicate over encrypted native database protocols, not HTTP.

- o Recommendation: Replace HTTP-based DB calls with TLS-secured native database driver connections (e.g., TLS-enabled PostgreSQL/MySQL).

Issue 4: No Redundancy -- Single Points of Failure

Every component in the DFD is a single instance. Any single failure brings the entire application down.

- o Recommendation: Deploy redundant Web and App Server instances behind a load balancer; implement database replication with automatic failover.

Section 3

Risk Analysis

Risk Evaluation -- Likelihood x Impact Scoring

Risks are ranked using a Likelihood x Impact matrix. Both dimensions are scored 1-5; the product gives a risk score (1-25). Higher scores represent greater priority for remediation.

Risk Scoring Formula

Risk Score = Likelihood (1-5) x Impact (1-5)

- o Likelihood: 1=Rare, 2=Unlikely, 3=Possible, 4=Likely, 5=Almost Certain
- o Impact: 1=Negligible, 2=Minor, 3=Significant, 4=Major, 5=Catastrophic

Risk Ranking Results (Completed)

- Rank 1 (Score 25): Authentication Requests Unencrypted in Transit [Likelihood 5 x Impact 5]
- Rank 2 (Score 20): Authentication Data Using Reversible Encryption [Likelihood 4 x Impact 5]
- Rank 3 (Score 12): Employee Data Unencrypted at Rest [Likelihood 3 x Impact 4]
- Rank 4 (Score 9): DES Algorithm in Use [Likelihood 3 x Impact 3]

Risk Rationale -- Ranks 1 and 2

#1: Authentication Requests Unencrypted in Transit (Score: 25)

- Likelihood: 5 (Almost Certain) -- The MitM attack is CONFIRMED. Logs provide irrefutable evidence of simultaneous logins from two different locations. The exploit is active and immediately repeatable.
- Impact: 5 (Catastrophic) -- Direct credential compromise achieved. The attacker can access any account, escalate privileges, and pivot to other vulnerabilities for full system compromise.
- Risk Score: $5 \times 5 = 25$ (maximum possible score).

Ranked #1 because this is not theoretical -- the exploit has already succeeded. An active, repeatable, confirmed attack demands the highest priority. Remediation is also the fastest to implement (deploy TLS).

#2: Authentication Data Using Reversible Encryption (Score: 20)

- Likelihood: 4 (Likely) -- The confirmed MitM and the lack of storage encryption (Rank 3) together create a realistic path to database access. Once access is achieved, decryption of all credentials is trivial.
- Impact: 5 (Catastrophic) -- All user credentials can be recovered in bulk from a single DB compromise, enabling mass account takeover and administrator-level access.
- Risk Score: $4 \times 5 = 20$.

Ranked #2 because bulk credential recovery from a DB compromise is catastrophic even though it requires an additional step beyond Rank 1.

Risk Rationale -- Ranks 3 and 4

#3: Employee Data Unencrypted at Rest (Score: 12)

- Likelihood: 3 (Possible) -- Requires physical access to storage media, a privileged DB account, or access to backup media. Higher barrier than network-based attacks, but the flat network in the DFD means a network attacker could pivot to reach the storage tier.
- Impact: 4 (Major) -- Complete exposure of all employee PII and timekeeping data. Significant GDPR regulatory breach with fines up to 4% of annual global turnover and mandatory public breach notification.
- Risk Score: $3 \times 4 = 12$.

Ranked #3 because physical/privileged access creates a higher exploitation barrier, but the regulatory and PII impact remains major.

#4: DES Algorithm in Use (Score: 9)

- Likelihood: 3 (Possible) -- An attacker must first obtain the DES ciphertext (requiring DB or storage access, as above) and then invest compute resources to brute-force the 56-bit key. A two-step exploit reduces likelihood.
- Impact: 3 (Significant) -- Scope is limited to data specifically protected by DES. Other data may use different controls. However, the lack of integrity protection in DES means affected fields could also be silently tampered with.
- Risk Score: $3 \times 3 = 9$.

Ranked #4 because exploitation requires prior access to ciphertext AND brute-force compute time -- the hardest attack to execute. However, it remains a critical compliance failure regardless of rank.

Section 4

Mitigation Plan

Mitigation 1: Employee Data Unencrypted at Rest

Recommended Mitigation Plan

Enable Transparent Data Encryption (TDE) on TimeSheetsDB and AuthDB using AES-256. Decrypt and re-encrypt existing data during a scheduled maintenance window. Store encryption keys in a Hardware Security Module (HSM) or cloud Key Management Service (e.g., AWS KMS, Azure Key Vault) -- physically and logically separated from the database servers. Enforce encryption on all database backups.

Why This Course of Action?

- TDE is a native RDBMS feature (SQL Server, PostgreSQL, MySQL Enterprise) operating at the storage layer with no application code changes required.
- AES-256 is NIST FIPS 197 approved and computationally infeasible to brute-force -- physical access to the disk is useless without the key.
- Storing keys in an HSM/KMS ensures the key and ciphertext are never co-located, eliminating single-point-of-compromise for the entire database.
- Encrypting backups closes the common physical theft vector where unencrypted backup tapes are removed from the premises.

Mitigation 2: Authentication Data Stored Using Reversible Encryption

Recommended Mitigation Plan

Migrate credential storage from reversible encryption to Argon2id (OWASP recommended) with minimum parameters: memory=64 MB, iterations=3, parallelism=4. Migration strategy: (1) Add a 'hash_algorithm' column; (2) On next successful login, re-hash the plaintext password with Argon2id; (3) Force password resets via email for users inactive for more than 30 days; (4) Retire and delete the old encryption key after all records are migrated.

Why This Course of Action?

- One-way hashing makes bulk password recovery computationally infeasible -- a full database export cannot yield passwords without per-hash brute-forcing.
- Argon2id won the Password Hashing Competition (2015) and is specifically memory-hard, resisting GPU, ASIC, and side-channel attacks.
- The phased migration minimises operational disruption while rapidly securing the most active accounts first.
- Deleting the old encryption key after migration removes residual risk -- legacy reversibly-encrypted records can no longer be decrypted.

Mitigation 3: Authentication Requests Unencrypted in Transit

Recommended Mitigation Plan

Deploy TLS 1.3 certificates on all externally-facing endpoints. Configure HTTP Strict Transport Security (HSTS) with max-age $\geq 31,536,000$ (1 year) and includeSubDomains. Redirect all HTTP (port 80) to HTTPS (port 443) at the load balancer/WAF. Enforce TLS on ALL internal connections: Web Server to App Server, and App Server to both databases. Disable TLS 1.0, 1.1, and weak cipher suites (RC4, 3DES, NULL).

Why This Course of Action?

- TLS 1.3 directly eliminates the confirmed MitM attack vector -- all credentials and session data become encrypted in transit.
- HSTS prevents SSL stripping attacks where an attacker downgrades the connection to HTTP before TLS is established.
- Enforcing TLS on internal connections (Boundaries 2 and 3 in the DFD) addresses insider threats and compromised-host pivot attacks.
- This is the highest-priority mitigation given the active exploit. Implementation time is hours; cost is near-zero with Let's Encrypt.

Mitigation 4: DES Algorithm in Use

Recommended Mitigation Plan

Conduct a full codebase audit (SAST scan via SonarQube or Semgrep with cryptography rule sets) to identify all DES usage. Replace with AES-256-GCM (authenticated encryption providing both confidentiality and integrity). Re-encrypt all DES-protected data during a maintenance window. Manage 256-bit keys via HSM/KMS (aligned with Mitigation 1). Add SAST checks to the CI/CD pipeline to prevent regression.

Why This Course of Action?

- AES-256 is the NIST FIPS 197 standard -- computationally infeasible to brute-force with any known technology.
- GCM mode (authenticated encryption, AEAD) provides both confidentiality AND integrity -- it detects any tampering with the ciphertext, fixing the integrity gap that DES in ECB/CBC mode leaves open.
- DES is explicitly prohibited under NIST SP 800-131A Rev. 2, making this a compliance requirement, not just best practice.
- CI/CD integration prevents regression: future commits using DES, 3DES, or RC4 automatically fail the build before reaching production.

Security Audit -- Ensuring Recommendations are Followed

1. Establish a Formal Encryption Policy

No encryption policy currently exists. The audit team should champion creation of an Encryption Standard mandating: AES-256 for data at rest, TLS 1.3 for data in transit, Argon2id/bcrypt for passwords, and explicit prohibition of DES, 3DES, RC4, MD5, and SHA-1.

2. Automated SAST in the CI/CD Pipeline

Integrate SonarQube or Semgrep with cryptography rule sets into the build pipeline. Any commit introducing deprecated algorithms fails the build automatically, preventing regression before code reaches production.

3. Quarterly Authenticated Vulnerability Scans

Use Nessus, Qualys, or OpenVAS to scan all in-scope systems quarterly. Authenticated scans detect misconfigurations that unauthenticated scans miss, including weak cipher suites and unencrypted storage.

4. Annual Penetration Testing

Commission a qualified third-party (CREST/CHECK certified) for annual pen tests covering network, web application, and database security. Include social engineering to test the insider-threat dimension.

5. SIEM Rule: Concurrent Session Detection

The MitM was detected by simultaneous logins from two IPs. Formalise this as a permanent SIEM alert: flag any account with concurrent active sessions from geographically or logically distant IP addresses.

6. TLS Certificate and Key Rotation Monitoring

Automate certificate expiry alerts at 30-day and 7-day thresholds. Enforce annual encryption key rotation with auditable rotation logs stored in the HSM/KMS.

Section 5

Residual Risk Acceptance & Review

Residual Risk Acceptance & Review

After mitigations are applied, some risk will remain (residual risk). This section formally documents accepted residual risks and establishes a review cadence -- both are required in any auditable threat model.

Residual Risk Register

- Unencrypted at rest -- Residual risk after TDE and encrypted backups: Low. Database administrators with approved key access can still read data through normal application and administrative paths.
- Reversible credential encryption -- Residual risk after Argon2id migration: Low. Password guessing remains possible against individual hashes, so MFA and rate limiting are still required.
- Unencrypted authentication requests -- Residual risk after TLS 1.3, HSTS, and internal mTLS: Low. Risk remains from endpoint compromise and misissued certificates.
- DES usage -- Residual risk after AES-256-GCM migration: Low. Risk remains from future cryptographic misuse, controlled through CI/CD checks and audit review.

Acceptance Criteria

- Residual risks rated Low may be formally accepted by the system owner.
- Residual risks rated Medium must have a compensating control documented.
- Residual risks rated High or Critical must be escalated to executive leadership and may not be accepted without written approval.

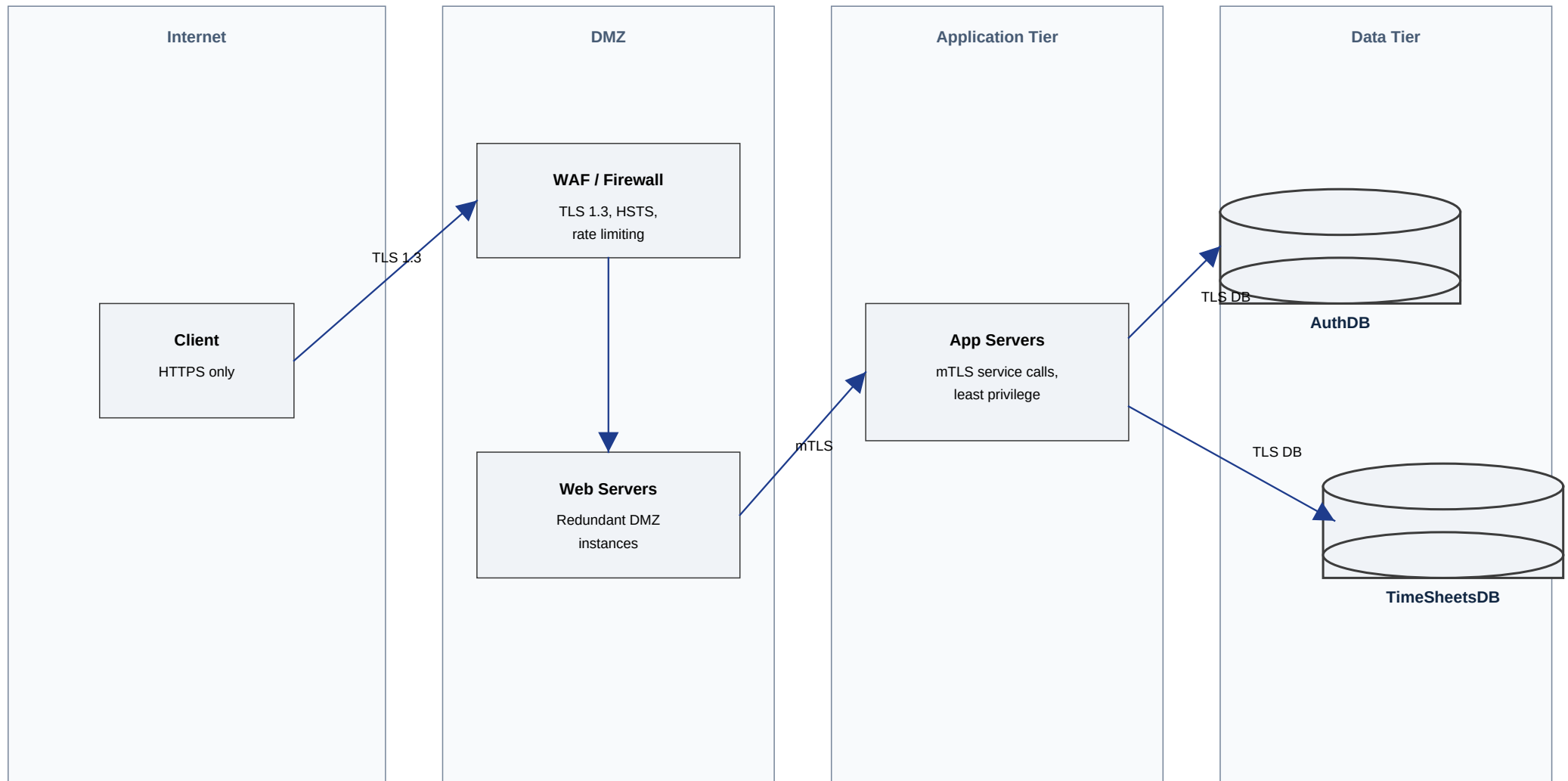
Review Schedule

- Next scheduled threat model review: within 12 months, or earlier after any significant architecture, authentication, cryptography, or data-store change.
- Owner responsible for triggering review: TimeSheets system owner with Security Engineering and SRE participation.

Validation

Each mitigation should be verified with evidence: TLS scan results, database encryption status, key-management logs, password-hash migration metrics, SAST results, and SIEM alert test records. Audit should retain this evidence with the risk register.

Secure Target Architecture -- TimeSheets



Security Controls Added

AES-256 TDE on both databases | Argon2id password hashes | Keys in HSM/KMS | encrypted backups | internal firewalls between tiers | SIEM alerts for concurrent sessions and anomalous access

Secure Architecture Diagram -- Control Mapping

The diagram below describes the recommended secure architecture that addresses all identified vulnerabilities and non-encryption issues.

Key Security Controls Added vs. Original Architecture

- Boundary 1: WAF/Firewall deployed in front of the Web Server. All traffic is TLS 1.3 encrypted (HTTPS only; HTTP redirected).
- Network Segmentation: Three isolated zones -- DMZ (Web Server), Application tier, Data tier -- separated by internal firewalls with least-privilege access rules.
- TimeSheetsDB and AuthDB: AES-256 TDE enabled on both databases. Encryption keys stored in a dedicated HSM/KMS.
- AuthDB: Credentials migrated to Argon2id one-way hashes.
- All inter-tier communication (Web->App, App->DB) uses TLS-secured protocols -- no unencrypted HTTP between internal components.
- Redundancy: Load balancer in front of dual Web/App Server instances; DB primary/replica replication with automatic failover.
- SIEM with concurrent-session and anomalous-access alerting.

Additional Preventative Recommendations

Additional steps beyond the four core mitigations to prevent this attack and reduce the risk of future incidents:

Multi-Factor Authentication (MFA)

Require MFA for all employee logins. Even if credentials are stolen via MitM, MFA prevents the attacker from completing authentication without the second factor. Use TOTP (RFC 6238) or hardware security keys (FIDO2).

Intrusion Detection/Prevention System (IDS/IPS)

Deploy a network IDS/IPS at Boundary 1 to detect and block known attack signatures (e.g., credential brute-forcing, SQL injection probes). Integrate alerts into the SIEM for centralised monitoring.

Privileged Access Management (PAM)

Enforce PAM controls for all database administrator accounts. Use just-in-time (JIT) privileged access with session recording and automatic de-provisioning after task completion.

Employee Security Awareness Training

The confirmed insider threat actor accessed data they do not normally access. Regular security awareness training (including data access policies) reduces the risk of malicious or inadvertent insider incidents.